

---

# Architecture Design Review

Consumer Notifications (APP-10016) — Application Context Diagram

Source: Relationship Visualizer.xlsm · RV-KGF v1.1 · view “knowledge” · exported 2026-09-28 19:23:59 · author not recorded

## Scope check

- After exclusions, the graph has **16 architectural nodes** (6 apps, 4 actors, 6 data stores) and **20 real edges** (5 app-to-app, 9 app-to-datastore, 6 actor-to-app).
- Excluded: 11 clusters, 9 notes and 2 transparent edges. There are no legend nodes and no defined: false nodes.
- Instance properties are present on all 16 nodes and on 19 of 20 edges; only System Timer → Consumer Notifications has none.
- No instance key duplicates a style key, so **there are no instance overrides anywhere**.
- Deviations from the spec: note nodes use style Note (resolved case-insensitively to note) and carry a properties: {id} field; failure keys appear on four non-queue data stores; several author keys fall outside the listed vocabulary (e.g. app\_id, business\_owner, vendor\_product, trigger\_source, failure\_impact, integrity).

## Headline findings

- **High:** unauthenticated, optionally encrypted SMTP from the SaaS CRM to the Mail Relay across the internet (R1); silent loss of audit records in Notification History (R2); no encryption at rest on any data store, three of which hold PII (R3).
- **Ratings:** Security, Data flow integrity and Observability are Weak; Scalability is Unclear.
- **Positives:** proxied, TLS-enforced egress with OAuth2 to the SaaS; queue-based decoupling with backoff and a Dead Letter Queue; no legacy or deprecated patterns.

# 1. Architecture Overview

**System boundary.** The diagram is the system context for **Consumer Notifications (APP-10016)**, a homegrown service that sends email notifications to consumers. SMS and push notifications are explicitly out of scope (Note 7). There are two use cases: a credit decision notification triggered by the Credit Application System, and a marketing email campaign driven by a Campaign Owner.

**Zones.** Two top-level trust zones sit inside the page border: **Corporate Applications** (Business to Consumer, Consumer Lending, Perimeter Network, Information Technology, Marketing Department) and **Internet** (Consumer's Home, Email Services, Cloud Service Provider).

**Control flow.** Requests reach Consumer Notifications in two ways: the Credit Application System calls it via ESB REST, and the Campaign Owner uploads a distribution list via web, which is read as a CSV. Consumer Notifications validates the template against a local Email Template Catalog and enqueues requests on the Notification Queue. A System Timer fires every minute; on each tick the app dequeues work and calls the Marketing CRM (Salesforce Marketing Cloud, SaaS) over HTTPS REST through the Forward Proxy. The CRM renders the template and sends it by SMTP to a Mail Relay, which delivers it to the consumer's mailbox.

**Failure handling.** Per Note 2 and the queue properties, delivery gets four attempts with exponential backoff, after which the request goes to a Dead Letter Queue for manual review. Events are written to Notification History (SQL) and faults to App Log Files. A single System Administrator builds templates in the CRM, manually catalogs them in Consumer Notifications, and monitors the queues and logs.

**Portfolio.** 2 homegrown (Consumer Notifications, Credit Application System), 2 internal platform “system” apps (Forward Proxy, Mail Relay), 1 vendor SaaS (Marketing CRM), 1 open-source-styled app (Email Client, though tagged vendor\_product: Microsoft Outlook), 0 partner. **0 of 14 system edges are legacy or deprecated:** 7 are modern and 7 established, and every edge that carries stability has the value Stable.

## 2. Component & Relationship Inventory

### 2.1 Zone hierarchy

| Zone                         | Parent    | Members                                                                                                                                  |
|------------------------------|-----------|------------------------------------------------------------------------------------------------------------------------------------------|
| Business to Consumer (B2C)   | Corporate | Consumer Notifications, System Timer, Notification Queue, Dead Letter Queue, App Log Files, Notification History, Email Template Catalog |
| Consumer Lending             | Corporate | Credit Application System                                                                                                                |
| Perimeter Network            | Corporate | Forward Proxy                                                                                                                            |
| Information Technology (IT)  | Corporate | System Administrator                                                                                                                     |
| Marketing Department         | Corporate | Campaign Owner, Distribution List                                                                                                        |
| Consumer's Home              | Internet  | Email Client, Consumer                                                                                                                   |
| Email Services               | Internet  | Mail Relay                                                                                                                               |
| Cloud Service Provider (CSP) | Internet  | Marketing CRM                                                                                                                            |

## 2.2 Components

| Name                      | Asset ID  | Kind / subtype         | Zone                      | Instance properties found                                                                                                                                                                                                                                                                    |
|---------------------------|-----------|------------------------|---------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Consumer Notifications    | APP-10016 | app / homegrown        | B2C                       | app_id, app_title, business_owner (Consumer Applications), technical_owner                                                                                                                                                                                                                   |
| Credit Application System | APP-10004 | app / homegrown        | Consumer Lending          | app_id, app_title, business_owner (Credit Operations), technical_owner                                                                                                                                                                                                                       |
| Forward Proxy             | APP-10011 | app / system           | Perimeter                 | app_id, app_title, owners (IT Infrastructure)                                                                                                                                                                                                                                                |
| Mail Relay                | APP-10013 | app / system           | Email Services (Internet) | app_id, app_title, owners (IT Infrastructure)                                                                                                                                                                                                                                                |
| Email Client              | APP-10014 | app / open_source      | Consumer's Home           | app_id, owners, vendor_product = Microsoft Outlook, comprehensive_list = false                                                                                                                                                                                                               |
| Marketing CRM             | APP-10018 | app / cloud            | CSP                       | vendor_product = Salesforce Marketing Cloud, hosting_model = SaaS, end_of_support_date = N/A, data_classification = Internal, contains_pii = true, redundancy_model = Active-Active, criticality = Medium, regulatory_scope = SOX, integrity / availability / business_continuity = Standard |
| System Timer              | —         | actor / event (system) | B2C                       | origin = Internal, trigger_source = System Clock, failure_impact = Degraded                                                                                                                                                                                                                  |
| System Administrator      | —         | actor / person (human) | IT                        | origin = Internal, population_scale = 1, trigger_source = Manual, failure_impact = Degraded                                                                                                                                                                                                  |
| Campaign Owner            | —         | actor / person (human) | Marketing                 | origin = Internal, population_scale = Up to 10                                                                                                                                                                                                                                               |
| Consumer                  | —         | actor / person (human) | Consumer's Home           | origin = External, population_scale = Up to 50,000                                                                                                                                                                                                                                           |
| Notification Queue        | —         | datastore / queue      | B2C                       | On Premise, Internal, <b>PII = true</b> , retention = 1 Year, <b>encryption_at_rest = false</b> , Daily Snapshots, retry = Exponential Backoff, disposition = Dead Letter Queue, alerting = Alert                                                                                            |
| Dead Letter Queue         | —         | datastore / queue      | B2C                       | On Premise, Internal, <b>PII = true</b> , retention = 1 Week, <b>encryption_at_rest = false</b> , Daily Snapshots, disposition = Manual Review, alerting = Alert (no retry_strategy)                                                                                                         |
| App Log Files             | —         | datastore / file       | B2C                       | Network Share, Internal, PII = false, retention = 1 Week, encryption_at_rest = false, Daily Snapshots, failure keys*                                                                                                                                                                         |
| Notification History      | —         | datastore / database   | B2C                       | On Premise, Internal, PII = false, retention = 5 Years, encryption_at_rest = false, Weekly Backups, <b>disposition = Discard, alerting = None</b>                                                                                                                                            |
| Email Template Catalog    | —         | datastore / database   | B2C                       | On Premise, Internal, PII = false, retention = 5 Years, encryption_at_rest = false, Weekly Backups, failure keys*                                                                                                                                                                            |
| Distribution List         | —         | datastore / file       | Marketing                 | deployment = <b>Local</b> , Internal, <b>PII = true</b> , retention = 1 Week, <b>encryption_at_rest = false, backup = None</b> , failure keys*                                                                                                                                               |

\* Failure keys on non-queue data stores are outside the expected semantics. They are reported, but their absence elsewhere is not counted as a gap.

## 2.3 Relationships

Enc. = resolved encryption\_in\_transit. All values come from the style, since there are no instance overrides. No edge style carries a preferred\_alternative.

| #   | Source → Target                                 | via / protocol        | Enc.           | Direction      | Zone crossing                    | Status                         | Instance properties                                                                                                     |
|-----|-------------------------------------------------|-----------------------|----------------|----------------|----------------------------------|--------------------------------|-------------------------------------------------------------------------------------------------------------------------|
| E1  | Credit App → Consumer Notifications             | esb / rest            | optional       | req/resp       | <b>Yes</b> (Lending→B2C)         | approved                       | Internal; PII = N; Service Account; Immediate / Return Error / <b>alert None</b> ; Low; agreements = Y; Stable          |
| E2  | Consumer Notifications → Forward Proxy          | forward_proxy / rest  | enforced       | req/resp       | <b>Yes</b> (B2C→Perimeter)       | <b>requires_approval</b>       | Internal; PII = N; Service Account; Immediate / <b>Fallback Route</b> / <b>alert None</b> ; Low; agreements = Y; Stable |
| E3  | Forward Proxy → Marketing CRM                   | direct_network / rest | enforced       | req/resp       | <b>Yes</b> (Corporate→Internet)  | approved                       | Internal; PII = N; OAuth2/OIDC; Immediate / Return Error / <b>alert None</b> ; Low; agreements = Y; Stable              |
| E4  | Marketing CRM → Mail Relay                      | email / smtp          | optional       | push           | <b>Yes</b> (CSP→Email Services)  | approved                       | Internal; PII = N; <b>auth None</b> ; Immediate / Fallback Route / <b>alert None</b> ; Low; agreements = Y; Stable      |
| E5  | Mail Relay → Email Client                       | email / smtp          | optional       | push           | <b>Yes</b> (Email Services→Home) | approved                       | Internal; PII = N; <b>auth None</b> ; Immediate / Fallback Route / <b>alert None</b> ; Low; agreements = Y; Stable      |
| E6  | Consumer Notifications → Notification Queue     | queue (enqueue)       | optional       | sends / write  | No                               | approved                       | Internal; <b>PII = Y</b> ; Service Account; None / Return Error / Logged Only; Low                                      |
| E7  | Consumer Notifications → Notification Queue     | queue (dequeue)       | optional       | gets / consume | No                               | approved                       | same as E6                                                                                                              |
| E8  | Consumer Notifications → Dead Letter Queue      | queue (enqueue)       | optional       | sends / write  | No                               | approved                       | same as E6                                                                                                              |
| E9  | Consumer Notifications → Dead Letter Queue      | queue (dequeue)       | optional       | gets / consume | No                               | approved                       | same as E6                                                                                                              |
| E10 | Consumer Notifications → App Log Files          | append                | not_applicable | sends / write  | No                               | approved                       | Internal; PII = N; Service Account; None / Return Error / Logged Only; Low                                              |
| E11 | Consumer Notifications → Notification History   | sql_insert            | optional       | sends / write  | No                               | approved (risk <b>medium</b> ) | Internal; PII = N; Service Account; None / <b>Discard</b> / Logged Only; Low                                            |
| E12 | Consumer Notifications → Distribution List      | read                  | not_applicable | gets / read    | <b>Yes</b> (B2C↔Marketing)       | approved                       | Internal; <b>PII = Y</b> ; Service Account; None / Return Error / Logged Only; Low                                      |
| E13 | Consumer Notifications → Email Template Catalog | sql_insert            | optional       | sends / write  | No                               | approved (risk <b>medium</b> ) | Internal; PII = N; Service Account; None / Return Error / Logged Only; Low                                              |
| E14 | Consumer Notifications → Email Template Catalog | sql_select            | optional       | gets / read    | No                               | approved                       | same as E13                                                                                                             |
| E15 | Consumer → Email Client                         | person_interacts      | — (unknown)    | bidirectional  | No                               | —                              | Internal; PII = Y; OAuth2; disposition = “Dead Letter Queue” (?); alert None; channel = Web; Mobile App                 |

| #   | Source → Target                               | via / protocol   | Enc. | Direction     | Zone crossing                   | Status | Instance properties                                            |
|-----|-----------------------------------------------|------------------|------|---------------|---------------------------------|--------|----------------------------------------------------------------|
| E16 | System Administrator → Consumer Notifications | person_interacts | —    | bidirectional | <b>Yes</b> (IT→B2C)             | —      | Internal; PII = N; OAuth2; Manual Review; Alert; channel = Web |
| E17 | System Administrator → Marketing CRM          | person_interacts | —    | bidirectional | <b>Yes</b> (Corporate→Internet) | —      | Internal; PII = N; OAuth2; Manual Review; channel = Web        |
| E18 | System Timer → Consumer Notifications         | event_sends_to   | —    | push          | No                              | —      | <b>None — all from style</b>                                   |
| E19 | System Administrator → Consumer Notifications | person_sends_to  | —    | push          | <b>Yes</b> (IT→B2C)             | —      | Internal; PII = N; OAuth2; Manual Review; channel = Web        |
| E20 | Campaign Owner → Consumer Notifications       | person_sends_to  | —    | push          | <b>Yes</b> (Marketing→B2C)      | —      | Internal; <b>PII = Y</b> ; OAuth2; Return Error; channel = Web |

### 3. Architecture Assessment

| Attribute                              | Rating   | Rationale                                                                                                                                                                                                                                                                                                                                                                          |
|----------------------------------------|----------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Security & trust boundaries            | Weak     | Encryption is optional on 9 system edges, including 3 zone-crossing edges (E1, E4, E5) and 4 PII edges (E6–E9), and on E4/E5 authentication is instance-confirmed None. <code>encryption_at_rest = false</code> on all 6 stores, 3 of which hold PII. Strengths: proxied egress to the SaaS (E2/E3, both TLS-enforced, OAuth2 at the internet hop) and OAuth2 on every human edge. |
| Scalability                            | Unclear  | Queue decoupling helps, but every edge reports <code>approximate_volume = Low</code> while the Consumer population is “Up to 50,000”, and dispatch is driven by a once-per-minute timer with a per-message REST call. The graph can't show whether a campaign burst fits.                                                                                                          |
| Resilience & availability              | Adequate | The core send path has exponential backoff, a 4-attempt DLQ and alerting on both queues, and the CRM is Active-Active. However, redundancy data is absent for Consumer Notifications, Forward Proxy and Mail Relay; “Fallback Route” on E2/E4/E5 has no modeled fallback; and E1 returns errors to the caller with no alerting.                                                    |
| Coupling & complexity                  | Adequate | Clean hub-and-spoke: ESB-mediated inbound, asynchronous queue, linear outbound chain. The weak point is the manual CRM ↔ Email Template Catalog sync, a human-mediated coupling between two copies of the same fact.                                                                                                                                                               |
| Data flow integrity                    | Weak     | Notification History (the audit record) discards failed inserts, and its node has alerting None. PII flags contradict each other along the same request path (E1–E3 = N, E6–E9 = Y). There is no return path for delivery status, bounces or unsubscribes. The DLQ keeps data for only 1 week against a manual-review process.                                                     |
| Maintainability & technology diversity | Adequate | Small, current portfolio: no legacy or deprecated patterns, all app-to-app edges Stable, owners on every app. <code>end_of_support_date</code> exists only for the SaaS (N/A), and vendor/product is unknown for the Forward Proxy and Mail Relay.                                                                                                                                 |
| Observability & operability            | Weak     | <code>failure_alerting = None</code> on all 5 app-to-app edges; all 9 datastore edges are “Logged Only”; logs sit on a network share with 1-week retention. Operations rely on one System Administrator (population 1) manually reviewing queues and logs.                                                                                                                         |

## 4. Key Risks & Weaknesses

| ID  | Weakness                                                                    | Affected                                                                     | Evidence type                                                    | Severity | Rationale                                                                                                                                                                                                                                                                            |
|-----|-----------------------------------------------------------------------------|------------------------------------------------------------------------------|------------------------------------------------------------------|----------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| R1  | Unauthenticated SMTP with opportunistic TLS from the SaaS CRM to Mail Relay | E4, Mail Relay                                                               | Instance fact (auth None, alert None) + Style default (optional) | High     | The edge crosses zones on the public internet, and the relay accepts mail with no authentication. An internally operated relay (system style, IT-owned) placed in the Internet zone raises open-relay and spoofing exposure for customer-facing credit mail. Failures are unalerted. |
| R2  | Silent loss of audit records                                                | E11, Notification History                                                    | Instance fact                                                    | High     | The edge has disposition Discard and only logs failures; the node has disposition Discard and alerting None. This is the store for auditability, traceability and compliance with 5-year retention, so lost inserts go undetected.                                                   |
| R3  | No encryption at rest on any data store, including PII                      | Notification Queue, Dead Letter Queue, Distribution List (+3 non-PII stores) | Instance fact                                                    | High     | The PII queue keeps data for 1 year and snapshots daily, multiplying unencrypted PII copies. The Distribution List is an unencrypted local CSV of consumer emails.                                                                                                                   |
| R4  | No alerting on the outbound delivery chain; undefined fallbacks             | E1-E5                                                                        | Instance fact                                                    | Medium   | All 5 app-to-app edges have alerting None and Immediate retry. "Fallback Route" on E2/E4/E5 matches no modeled path and conflicts with the DLQ design in Note 2. On E1, a failed credit-decision notification returns to the caller silently.                                        |
| R5  | PII and classification under-declared on the credit path                    | E1, E2, E3                                                                   | Instance fact (inconsistency)                                    | Medium   | The same request is flagged PII on the queue edges (E6-E9) and on the CRM node, yet <code>contains_pii = false</code> on the inbound call and the internet egress. Credit decision content is classified only as Internal. Controls sized to these labels will be too weak.          |
| R6  | Opportunistic TLS on SMTP delivery to consumers                             | E5                                                                           | Style default (optional) + Instance fact (auth None)             | Medium   | Credit-decision mail crosses into Consumer's Home with no guarantee of encryption.                                                                                                                                                                                                   |
| R7  | Optional encryption on a cross-zone ESB REST call                           | E1                                                                           | Style default                                                    | Medium   | Crosses Consumer Lending → B2C. TLS depends on ESB listener configuration, which is unverified.                                                                                                                                                                                      |
| R8  | Optional encryption on queue traffic carrying PII                           | E6, E7, E8, E9                                                               | Style default + Instance fact (PII = Y)                          | Medium   | Mitigated somewhat by staying in one zone and using service-account auth. Broker TLS is still unverified.                                                                                                                                                                            |
| R9  | Distribution List handling                                                  | Distribution List, E12, E20                                                  | Instance fact + Inferred                                         | Medium   | PII CSV with deployment "Local", backup None and no encryption at rest, read by file I/O across the B2C ↔ Marketing boundary. A style of <code>not_applicable</code> implies local I/O, but crossing zones implies a network share protocol whose encryption is unknown.             |
| R10 | Retention mismatches                                                        | Notification Queue, Dead Letter Queue                                        | Instance fact                                                    | Medium   | A 1-year retention of PII on a queue whose style says <code>transient</code> over-retains PII. A 1-week retention on the DLQ can purge items before manual review resolves them.                                                                                                     |
| R11 | No delivery-status or suppression return path                               | Marketing CRM → Consumer Notifications (absent)                              | Inferred                                                         | Medium   | Notification History claims delivery histories, but only send attempts are observable. Bounces and unsubscribes (relevant to Use Case 2) never return.                                                                                                                               |
| R12 | Possible single points of failure; resilience data missing                  | Consumer Notifications, Forward Proxy, Mail Relay                            | Inferred                                                         | Medium   | Every flow passes through Consumer Notifications, and all outbound flow passes through one proxy and one relay. No <code>redundancy_model</code> or <code>criticality</code> is recorded for them.                                                                                   |

| ID  | Weakness                                           | Affected                                 | Evidence type                           | Severity | Rationale                                                                                                                                                    |
|-----|----------------------------------------------------|------------------------------------------|-----------------------------------------|----------|--------------------------------------------------------------------------------------------------------------------------------------------------------------|
| R13 | Scale not evidenced                                | E1-E5, E18                               | Inferred                                | Medium   | “Low” volume everywhere vs. 50,000 recipients; per-message REST plus 1-minute polling could miss campaign timing or hit CRM API limits.                      |
| R14 | Key-person operations; direct admin access to SaaS | System Administrator, E17                | Instance fact (population 1) + Inferred | Medium   | One person runs operations, template authoring and catalog sync. E17 crosses Corporate → Internet with no modeled proxy or conditional-access path.          |
| R15 | Manual template catalog sync                       | E13, E14, Email Template Catalog, Note 4 | Inferred                                | Low      | Validation (E14) checks a local copy, not the CRM, so drift causes delivery failures that only surface downstream.                                           |
| R16 | Forward-proxy pattern requires approval            | E2                                       | Style default                           | Low      | agreements_in_place = true does not show that the architecture approval or exception exists.                                                                 |
| R17 | Style mismatch on internet egress                  | E3                                       | Style default vs. Inferred              | Low      | direct_network_https_rest is described as being on the internal network but models Perimeter → Internet SaaS, so its approved status may not cover this use. |

**None triggered:** no prohibited, deprecated or under\_review status; no high risk\_level; no encryption\_in\_transit = none; no Deprecated stability; no Unhandled disposition; no known end-of-support date within 12 months.

## 5. Proposed Mitigations

No affected edge style defines a preferred\_alternative, so none is recommended.

| Risk | Recommended mitigation                                                                                                                                                                                                                                                                                      | Priority | Effort | Rationale                                                                                        |
|------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------|--------|--------------------------------------------------------------------------------------------------|
| R1   | Restrict relay acceptance to the CRM's published IP ranges and require SMTP AUTH or mutual TLS on submission. Enforce TLS on the CRM → relay hop, publish SPF/DKIM/DMARC for the sending domain, and alert on relay rejects. Alternatively, retire the hop and let the CRM send directly under your domain. | High     | Medium | Closes the unauthenticated, unencrypted internet hop.                                            |
| R2   | Write the history record in the same transaction as the enqueue (outbox pattern), or route failed inserts to a retry queue or DLQ with alerting. Change the disposition from Discard.                                                                                                                       | High     | Medium | Compliance records must not be lossy.                                                            |
| R3   | Enable broker/disk encryption for both queues, TDE for both databases, and an encrypted share for the logs. Start with the three PII stores.                                                                                                                                                                | High     | Medium | Removes plaintext PII at rest, including snapshot copies.                                        |
| R4   | Add alerting on E1-E5. Replace “Fallback Route” with the DLQ path already modeled, or document the actual fallback. Change Immediate retry to backoff with jitter, consistent with the queue policy.                                                                                                        | High     | Low    | Makes delivery failures visible and avoids retry storms.                                         |
| R5   | Set contains_pii = true on E1-E3 and reassess credit-decision content as Confidential. Confirm the CRM DPA covers it.                                                                                                                                                                                       | Medium   | Low    | Labels drive encryption, logging and vendor controls.                                            |
| R6   | Minimize content (“your decision is ready — sign in”) rather than including decision details. Adopt MTA-STS and TLS-RPT on the sending domain.                                                                                                                                                              | Medium   | Low    | TLS to arbitrary consumer MX hosts can't be forced; limiting sensitive content reduces exposure. |
| R7   | Require TLS on the ESB listener and route for the Consumer Notifications endpoint; record encryption_in_transit at instance level.                                                                                                                                                                          | Medium   | Low    | Converts “optional” into a verified fact.                                                        |
| R8   | Configure TLS-only broker listeners and reject plaintext clients.                                                                                                                                                                                                                                           | Medium   | Low    | Same as R7, for the PII-bearing queue traffic.                                                   |

| Risk | Recommended mitigation                                                                                                                                                                                                     | Priority | Effort | Rationale                                                   |
|------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------|--------|-------------------------------------------------------------|
| R9   | Store uploads (E20) in controlled, encrypted storage inside B2C instead of a Marketing-zone local file. Delete after processing and document the actual transfer path.                                                     | Medium   | Low    | Removes a cross-zone, unbacked PII file.                    |
| R10  | Cut Notification Queue retention to the delivery window, since history holds the audit trail. Set DLQ retention longer than the manual-resolution SLA and add age-based alerts.                                            | Medium   | Low    | Balances data minimization with recoverability.             |
| R11  | Add a CRM → Consumer Notifications status, bounce and unsubscribe feed (webhook via reverse proxy, or scheduled pull via the forward proxy) into Notification History. Check the suppression list before campaign enqueue. | Medium   | Medium | Gives true delivery history and campaign compliance.        |
| R12  | Record <code>redundancy_model</code> and <code>criticality</code> for Consumer Notifications, Forward Proxy and Mail Relay, and provide HA for the proxy and relay if absent.                                              | Medium   | Medium | The shared egress path can't be assessed without this data. |
| R13  | Load-test a 50k campaign, confirm the CRM API rate limits, and consider the CRM's bulk or journey send instead of per-message REST.                                                                                        | Medium   | Medium | Validates capacity before a campaign depends on it.         |
| R14  | Train a second administrator and separate the template-authoring role. Put CRM admin access behind corporate SSO and conditional access.                                                                                   | Medium   | Low    | Reduces key-person and unmanaged-access risk.               |
| R15  | Validate template existence against the CRM API at request time, or sync the catalog automatically.                                                                                                                        | Low      | Medium | Removes manual drift.                                       |
| R16  | Obtain and record the approval, and add an approval-reference instance property to E2.                                                                                                                                     | Low      | Low    | Closes a governance gap.                                    |
| R17  | Restyle E3 with an internet-egress pattern, or confirm the governance position covers it.                                                                                                                                  | Low      | Low    | Keeps status meaningful.                                    |

## 6. Assumptions & Open Questions

### 6.1 Note text (excluded annotation nodes)

| Note | Zone             | Text                                                                                                                                   |
|------|------------------|----------------------------------------------------------------------------------------------------------------------------------------|
| 1    | B2C              | Business application uses the Consumer Notifications application to send graphics-rich emails to customers.                            |
| 2    | B2C              | Four delivery attempts are made. After four failures, the request moves to the Dead Letter Queue of manual resolution.                 |
| 3    | Consumer Lending | An in-house application used to process customer credit applications, assess creditworthiness, and manage credit risk.                 |
| 4    | IT               | System Administrator creates email templates in the Marketing CRM and catalogs them in Consumer Notifications for use.                 |
| 5    | Marketing        | Campaign Owner uploads the targeted customer distribution list, selects the email template, and designates when delivery should occur. |
| 6    | CSP              | Consumer Notifications application uses cloud-based SAAS software to compose and deliver the message.                                  |
| 7    | Page             | Consumer Notifications involving mobile text messages and push notifications are outside the scope of this context diagram.            |
| 8    | Page             | Use Case 1: Consumer has applied for credit, and is waiting to learn of the decision.                                                  |
| 9    | Page             | Use Case 2: Sales and Marketing is running an email campaign.                                                                          |

## 6.2 Data-collection gaps

| Element kind                  | Coverage                                                                                                                                                                                                                                                                |
|-------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Apps (6)                      | app_id, app_title and both owners on 6/6. vendor_product on 2/6. hosting_model, end_of_support_date, criticality, redundancy_model, regulatory_scope, data_classification, contains_pii, integrity, availability, business_continuity each on only 1/6 (Marketing CRM). |
| Actors (4)                    | origin 4/4; population_scale 3/4; trigger_source and failure_impact 2/4.                                                                                                                                                                                                |
| Data stores (6)               | All descriptive keys on 6/6. Failure keys counted against queues only: failure_disposition and failure_alerting 2/2, retry_strategy 1/2 (missing on the Dead Letter Queue).                                                                                             |
| App-to-app edges (5)          | All 9 keys on 5/5.                                                                                                                                                                                                                                                      |
| App-to-datastore edges (9)    | 7 keys on 9/9; agreements_in_place and stability on 0/9.                                                                                                                                                                                                                |
| Actor-to-app edges (6)        | data_classification, contains_pii, auth_mechanism, failure_disposition and channel on 5/6. retry_strategy, failure_alerting and approximate_volume on 2/6.                                                                                                              |
| Not present anywhere          | security_boundary_crossed, and any instance encryption_in_transit.                                                                                                                                                                                                      |
| No instance properties at all | E18, System Timer → Consumer Notifications; its attributes come solely from the event_sends_to style.                                                                                                                                                                   |

## 6.3 Approvals and configurations to confirm

- **Approval to confirm:** E2 (Consumer Notifications → Forward Proxy, requires\_approval). agreements\_in\_place = true is not an explicit approval record.
- **Encryption configurations to confirm:** E13 and E14 (SQL to the Email Template Catalog), and E11 (SQL to Notification History; its R2 risk covers failure handling only). E1 and E4–E9 are already covered in the risks.

## 6.4 Clarifying questions for the architecture team

1. Who operates the Mail Relay: the organization (per its system style and IT ownership) or a third-party email service (per its Internet zone)? Is it reachable from the internet, and how does it restrict senders?
2. Is the Email Client meant to represent any consumer's mail client? It carries a corporate asset ID, IT ownership, an open-source style and vendor\_product Microsoft Outlook. SMTP normally terminates at the consumer's mail provider, not the client.
3. What exactly is the “Fallback Route” on E2, E4 and E5?
4. Does the credit notification contain the decision itself, or only a prompt to sign in? Is it relied on as a regulatory adverse-action notice?
5. Why are E1–E3 flagged contains\_pii = false when they carry the consumer's email address to the SaaS?
6. Where does “Local” place the Distribution List, and what protocol does E12 actually use across zones?
7. What is the realistic peak volume per campaign, and what are the CRM API rate limits?
8. What are the redundancy, criticality and end-of-support positions for Consumer Notifications, Forward Proxy, Mail Relay and the Credit Application System?
9. On E15 (a consumer reading email), what does failure\_disposition = “Dead Letter Queue” mean? It looks like a data-entry error.
10. Does System Administrator access to the CRM (E17) go through the Forward Proxy, SSO or conditional access?

**Confidence.** Instance data is rich for data stores and app-to-app edges, so the security and integrity findings are well grounded. Scalability and resilience conclusions are limited by missing volume and redundancy data for everything except the CRM.